PDF Tool

Audit #3 — Privacy Architecture Release

Live: https://pdftool4u.duckdns.org (AWS EC2)
Repository: github.com/mukeshroyhub/pdf_tool
Date: 16 July 2026 · Prepared for: Mukesh Kumar

OVERALL PRODUCTION READINESS	92 / 100

Up from 89 at the previous audit. The privacy architecture is a genuine product differentiator and shrinks the security surface. One urgent finding: the old Render deployment is still publicly serving the previous version.

1. Executive Summary

Since the last audit, PDF Tool has undergone its most significant change yet: a **privacy-first re-architecture**. Files now live exclusively in the user's browser (IndexedDB). Server tools process bytes just-in-time — staged, processed, returned, deleted — and the server-side activity log has been removed entirely. The server database now stores no information about any user's files, verified by updated tests that assert an empty activity log after every operation.

On top of that: a UI polish round (upload-first dashboard, tool cards that open a file picker, dismissible privacy banner, guest badge, accurate browser-storage meter), a decluttered viewer (Tools dropdown), a password prompt for encrypted PDFs, inline image preview, and a public, SEO-ready /help guide covering all 13 features. Operational gaps from audit #2 were closed: exposed secrets were rotated and an UptimeRobot monitor now watches /api/health.

The one urgent finding: the retired Render deployment is still live and publicly serving the old server-storage version of the app. It responded to a health check during this audit. Anyone who finds that URL gets the pre-privacy build — and files they upload there are stored server-side. It must be suspended.

Scorecard vs. audit #2

Area	Score	Δ	Note
Architecture	**9.5**	▲	Browser-local library + stateless processing; clear differentiator
Security & privacy	**9.0**	▲	Server stores nothing about files; secrets rotated; strict CSP kept prod-only
Deployment / DevOps	**8.5**	▲	Monitoring live; Render retirement pending; root containers remain
Code quality	**8.5**	=	New local-store/local-ops layers clean and documented; tests updated
Features & UX	**9.5**	▲	Password prompt + image preview close real gaps; viewer decluttered
Testing / CI	**7.5**	▲	CI caught a real contract break this cycle; still no E2E
Performance	**8.0**	▲	Server now stateless per-op; staging round-trip adds bandwidth
Documentation	**9.5**	▲	Public /help guide for every feature + deploy guides + audits

2. Privacy Architecture Review

The hybrid design is sound and well-executed:

- **Browser library (local-store.ts):** IndexedDB v2 with separate files and activity stores; clean promisified transactions; metadata mirrors the old server DTO so the UI needed no changes.
- **Just-in-time processing (local-ops.ts):** stage → run → absorb → cleanup, with cleanup in `finally` blocks so server copies are deleted even when an operation fails.
- **Defense in depth:** if a browser disconnects mid-operation and cleanup never runs, the 60-minute retention job purges the orphaned staged files; stale guest accounts are purged after 24 h.
- **Verified in production:** live logs during rollout showed the full stage/process/download/delete cycle with all server copies removed; the storage meter reads 0 B server-side.

- **Tests updated:** three suites now assert the activity endpoint returns zero entries — guarding against anyone reintroducing server-side logging.

Honest limitations (by design, documented in the UI)

- Files transit the server momentarily during tool runs (unavoidable for server-side processing).
- Files are per-device: clearing browser data deletes them; no cross-device sync. The dashboard banner and /help page state this clearly.
- Staging doubles bandwidth per operation (upload + download). Acceptable at current scale.

3. Findings & Recommendations

#	Severity	Finding	Recommendation
F1	**HIGH**	Old Render deployment still live, publicly serving the pre-privacy build with server-side file storage (health check answered during this audit).	Suspend/delete both Render services now. Optionally keep the repo's render.yaml for reference only.
F2	**MEDIUM**	Containers run as root (no USER directive in Dockerfiles).	Add a non-root user to both images.
F3	**MEDIUM**	Settings page still shows an Activity-logging toggle that now controls nothing (server logging is a no-op).	Remove the toggle or repoint it at the browser-local activity log.
F4	**LOW**	Reproducible builds: lockfile still deleted in CI/Docker (Windows lockfile issue).	Commit a Linux-generated lockfile when convenient.
F5	**LOW**	No E2E tests; the browser-side library (IndexedDB flows) has no automated coverage at all — it is exercised only manually.	Add a small Playwright suite: upload → tool → download round-trip.
F6	**LOW**	Elastic IP not confirmed; a stop/start changes the public IP and silently breaks DuckDNS until re-pointed.	Allocate + attach an Elastic IP (free while attached).
F7	**INFO**	No sitemap/robots; the new /help page is SEO-ready but undiscovered.	Add sitemap.xml + robots.txt, register in Google Search Console.
F8	**INFO**	Mobile layout untested on real devices.	Quick pass on a phone; fix what surfaces.

4. Closed Since Audit #2

- **S1 Secret rotation (was CRITICAL):** Neon, Supabase, Brevo and Google secrets rotated; old GitHub PATs revoked. ✔
- **Monitoring (was P0):** UptimeRobot pings /api/health every 5 minutes with email alerts. ✔
- **Server data exposure:** eliminated architecturally — nothing about user files is stored server-side. ✔
- **Viewer gaps found by the owner:** encrypted PDFs now prompt for a password in-viewer; converted images preview inline. ✔
- **Toolbar clutter:** six secondary actions collapsed into a Tools dropdown. ✔
- **Discoverability:** public /help guide with 13 step-by-step feature walkthroughs, verified live. ✔

5. Action Plan

Priority	Action
P0 — today	Suspend both Render services (F1). Two clicks; removes a live copy of the old architecture.
P1 — this week	Delete old Google OAuth secret if not yet done; attach an Elastic IP (F6); remove or repoint the stale activity toggle (F3).
P2 — soon	Non-root containers (F2); sitemap + Search Console (F7); mobile pass (F8).
P3 — later	Playwright E2E suite (F5); Linux lockfile (F4); offline PWA — the natural next feature for a browser-local app.

6. Verdict

92/100 — production-ready with a distinctive privacy story. The browser-local architecture is the kind of design decision that separates a portfolio project from a product: it is honest (limitations are documented in the UI), defensible (tests enforce it), and marketable (the /help page leads with it). The codebase remains clean and layered; CI proved its worth this cycle by catching a real regression. Close F1 today — a live copy of the old architecture undermines the privacy promise the new one makes. After that, the remaining items are incremental hardening and growth, not fixes.

Automated senior-engineer audit of the codebase and live deployment, 16 July 2026. Third audit in series (previous: 89/100).